

CO4

Assessment

Tool - 03

Case study

Name : A. Bhavya

Reg no : 192424417

Course code : ITA1408

Course Name: ethical hacking

17 E-commerce Web Application Security

Attack vectors:

The e-commerce application may be attacked through multiple weakness. The outdated Apache server may contain known vulnerabilities that attackers can exploit. Hidden directories can reveal sensitive files or administrative pages. Improper input validation can allow XSS and other injection attacks. Weak authentication and session management may also allow attackers to access customer accounts.

Security Assessment using Kali Linux

The assessment begins with reconnaissance using Nmap and Whatweb to identify open ports, services, server technologies and application details. Nikto can be used to identify common Web-server misconfigurations and outdated components. Burp suite can intercept HTTP requests and help test input fields, cookies, authentication and session management. Gobuster can be used in an authorized environment to identify exposed directories.

Impact

Successful exploitation could lead to customer account compromise, unauthorized transactions, data theft

website modification and financial losses.

Counter measures :

The company should update Apache and operating-system packages, disable unnecessary services, implement secure input validation and output encoding, use secure authentication and session management, and deploy a WAF, firewalls, IDS/IPS, network segmentation, centralized logging and regular penetration testing should also be implemented.

2) SQL injection and XSS

Vulnerability Analysis :

SQL injection occurs when user inputs is directly incorporated into database queries. Attackers may manipulate queries to access or modify sensitive information. XSS occurs when malicious input is displayed in a user's browser without proper encoding, allowing attacker-controlled scripts to execute.

Testing Methodology :

First, the tester performs reconnaissance using Nmap and Whatweb. Burp Suite is then used to capture login

search and transaction requests and identify parameters that accept user input. In an authorized test environment, SQLmap can be used to validate suspected SQL injection vulnerabilities. Burp Suite can also be used to test for reflected and stored XSS using harmless proof-of-concept payloads.

CIA Impact:

Confidentiality: Customer & financial information may be exposed.

Integrity: Transactions or records could be modified.

Availability: Database corruption or application disruption may take services unavailable.

Mitigation:-

Use parameterized queries and prepared statements to prevent SQL injection. Validate input on the server side and apply context-aware output encoding to prevent XSS. Detailed database errors should not be shown to users. Secure cookies, session expiration, MFA, content security policy and proper access control should also be implemented.

③

Evil Twin Wireless Attack

Attack Analysis:

An Evil twin attack occurs when an attacker creates a rogue access point using the same SSID as the legitimate corporate network. Employees may automatically connect to the stronger or more familiar signal. The attacker can then monitor network activity or attempt to collect credentials through fraudulent authentication pages.

Detection:

Aircrack-ng can be used in an authorized assessment to identify wireless networks, BSSIDs, channels and encryption methods. Wireshark can analyze packet captures to identify unusual authentication activity, duplicate access points and suspicious traffic.

Weakness:

The use of WPA2-PSK with a shared password makes the environment more difficult to control because many users share the same credential. Lack of rogue-AP detection and poor user awareness further increases the risk.

Countermeasures

The organization should move toward WPA2-Enterprise with 802.1x/RADIUS, deploy wireless intrusion detection, segment employee and guest networks, monitor rogue access points and train employee to recognize suspicious WiFi networks and certificate warnings.

4. Wireless and Web Applications Attack chain

Attack chain:

The attacker first compromises the weak Wi-Fi password and obtains access to the internal network. The attacker then performs reconnaissance using Nmap to identify active hosts and services. The web application is examined using Burp suite to identify authentication, session and authorization weakness.

The attacker may then exploit weak session management or broken access control to access functions belonging to higher-privileged users. If successful, confidential employee information may be accessed.

Kali linux tools

- Aircrack-ng: Wireless security assessment.
- Nmap: Host and service discovery.

- Nikto: Web - server assessment
- Burp suite: Web application and session testing

Security Framework

Wireless security should use WPA 3 - Enterprise and strong authentication. Internal systems should be separated using VLANs and firewall rules. The web application should implement MFA, secure sessions, role-based access control and server-side authorization. Logs should be centrally monitored using a SIEM.

Wireless Deauthentication Attack

Attack Analysis:

A deauthentication attack targets Wi-Fi management frames and attempts to force legitimate clients to disconnect from an access point. Repeated attacks can continuously disconnect users and cause serious service disruption.

Detection and Analysis:

In an authorized laboratory, Aircrack-ng can be used to monitor wireless activity. Wireshark can

analyze packet captures and identify unusually high numbers of deauthentication frames and repeated client reconnections.

Impact

The primary impact is on availability. Students and employees may lose internet connectivity. Online classes or examinations may be interrupted, and productivity may decrease.

Countermeasures

Organizations should enable Protected Management Frames (PMF) and use WPA3 where supported. Wireless IDS/IPS should be deployed to detect abnormal management-frame activity. Access-point firmware should be updated regularly, and network administrators should monitor unusual disconnection patterns.

Conclusion:

Deauthentication attacks mainly threaten network availability and can significantly affect users and productivity. Protected Management Frames, WPA3, Wireless IDS/IPS, regular monitoring and updated access points can help detect and reduce such attacks.